

SECCIÓN 3.2



Interpretación de tráfico HTTPS y comunicaciones cifradas

Temas de esta sección:

- Por qué HTTPS no significa automáticamente seguro
- Qué puede analizar el SOC aunque el contenido esté cifrado
- Metadatos útiles: proceso, dominio, frecuencia, volumen
- El proceso importa más que el puerto
- Beaconing: comunicación periódica legítima vs sospechosa
- Servicios legítimos abusados (GitHub, Drive, Pastebin)
- HTTPS y exfiltración / descargas sospechosas

Con HTTPS, el contenido viaja cifrado entre cliente y servidor. Pero los metadatos todavía son visibles.

✗ NO podemos ver directamente

- Contenido exacto de la página
- Credenciales enviadas
- Archivos transferidos
- Comandos dentro de la sesión
- Payloads internos
- Parámetros sensibles

✓ Sí podemos observar

- Host y usuario de origen
- Proceso que generó la conexión
- Dominio e IP de destino
- Puerto y protocolo
- Hora, frecuencia y duración
- Volumen enviado y recibido
- Certificado TLS (si disponible)
- Acción del control
- Consulta DNS previa

HTTPS cifra contenido. No oculta todo el comportamiento.

3.2 | El proceso importa más que el puerto — escalera de sospecha



El mismo puerto 443. Cuatro interpretaciones distintas:

<code>chrome.exe → https://sharepoint.com</code>	ESPERADO	Proceso normal, destino corporativo conocido.
<code>powershell.exe → https://unknown-domain.com</code>	REQUIERE ANÁLISIS	Proceso que no suele navegar, destino desconocido.
<code>WINWORD.EXE → powershell.exe → https://unknown-domain.com</code>	SOSPECHOSO	Cadena de ejecución anómala. Word no debería lanzar PowerShell.
<code>WINWORD.EXE → powershell.exe -enc → https://unknown.com → descarga update.exe</code>	CRÍTICO	Secuencia completa compatible con ejecución inicial maliciosa.

El puerto es el mismo. La interpretación cambia por la secuencia.



El **beaconing** es una comunicación periódica donde un sistema se conecta repetidamente para enviar/recibir instrucciones. Puede ser legítimo o malicioso según el contexto.

BEACONING LEGÍTIMO

```
Process: edr_agent.exe
Destination: console.securityvendor.com
Frequency: Every 60 seconds
Signed: Yes
Path: C:\Program Files\SecurityVendor\
```

- Proceso conocido y firmado
- Ruta corporativa esperada
- Destino de proveedor de seguridad
- Comportamiento documentado

BEACONING SOSPECHOSO

```
Process: update.exe
Destination: cloud-sync-check.net
Frequency: Every 60 seconds
Signed: No
Path: C:\Users\Public\
Parent Process: powershell.exe
First seen: Today
```

- Proceso sin firma
- Ruta pública de usuario
- Destino nuevo y desconocido
- Proceso padre: PowerShell
- Primera vez observado hoy



Los atacantes pueden ocultar actividad usando servicios conocidos y confiables:

GitHub	Dropbox	Google Drive	OneDrive	Discord
Telegram	Pastebin	Cloudflare	AWS / Azure / GCP	CDN públicas

⚠ El destino puede parecer legítimo. La pregunta correcta es: ¿ese uso tiene sentido en este contexto?

```
Host: HR-LAP-041
User: rrhh.silva
Process: powershell.exe
Parent Process: WINWORD.EXE
Destination: raw.githubusercontent.com
Port: 443 | Action: Allowed
Bytes Received: 350 KB
File Created: C:\Users\Public\script.ps1
```

GitHub no es malicioso.

Pero PowerShell desde Word descargando un script en un equipo de RRHH SÍ es sospechoso.

La pregunta no es '¿GitHub es malicioso?'

La pregunta es '¿este uso de GitHub tiene sentido en este contexto?'